

数据库原理单人三级项目报告

项目名称：项目 2 — 数据库安全性

学号

姓名

2024611010

陈正洋

年级专业：

24 计科

=====

适用 DBMS: MySQL 8.0+

1. 创建用户和角色

1.1 创建用户

创建三个用户：user1、user2、user3，分别对应不同的权限级别。

```
CREATE USER 'user1'@'localhost' IDENTIFIED BY 'password1';  
CREATE USER 'user2'@'localhost' IDENTIFIED BY 'password2';  
CREATE USER 'user3'@'localhost' IDENTIFIED BY 'password3';
```

```
mysql> CREATE USER 'user1'@'localhost' IDENTIFIED BY 'password1';  
Query OK, 0 rows affected (0.00 sec)  
  
mysql> CREATE USER 'user2'@'localhost' IDENTIFIED BY 'password2';  
Query OK, 0 rows affected (0.00 sec)  
  
mysql> CREATE USER 'user3'@'localhost' IDENTIFIED BY 'password3';  
Query OK, 0 rows affected (0.00 sec)
```

1.2 创建角色

创建三个角色：role_manager（管理员）、role_operator（操作员）、role_viewer（只读用户）。

```
CREATE ROLE 'role_manager';
CREATE ROLE 'role_operator';
CREATE ROLE 'role_viewer';
```

```
mysql>
mysql> CREATE ROLE 'role_manager';
Query OK, 0 rows affected (0.00 sec)

mysql> CREATE ROLE 'role_operator';
Query OK, 0 rows affected (0.00 sec)

mysql> CREATE ROLE 'role_viewer';
Query OK, 0 rows affected (0.00 sec)
```

2. 将用户加入到角色

```
-- 基础角色分配
GRANT 'role_manager' TO 'user1'@'localhost';
GRANT 'role_operator' TO 'user2'@'localhost';
GRANT 'role_viewer' TO 'user3'@'localhost';

-- user1 额外加入 operator 和 viewer 角色
GRANT 'role_operator', 'role_viewer' TO 'user1'@'localhost';

-- 查看用户的角色
SELECT * FROM mysql.user_roles WHERE user = 'user1';
```

```
mysql> GRANT 'role_manager' TO 'user1'@'localhost';
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT 'role_operator' TO 'user2'@'localhost';
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT 'role_viewer' TO 'user3'@'localhost';
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT 'role_operator', 'role_viewer' TO 'user1'@'localhost';
Query OK, 0 rows affected (0.00 sec)
```

3. 授权（表级和列级，带 WITH GRANT OPTION）

3.1 表级授权

授予 role_manager 对 SPJ 数据库所有表的全部权限（WITH GRANT OPTION）：

```
GRANT ALL PRIVILEGES ON SPJ.* TO 'role_manager' WITH GRANT OPTION;
```

授予 role_operator 对四个表的 SELECT、INSERT、UPDATE 权限：

```
GRANT SELECT, INSERT, UPDATE ON SPJ.S TO 'role_operator' WITH GRANT OPTION;
GRANT SELECT, INSERT, UPDATE ON SPJ.P TO 'role_operator' WITH GRANT OPTION;
GRANT SELECT, INSERT, UPDATE ON SPJ.J TO 'role_operator' WITH GRANT OPTION;
GRANT SELECT, INSERT, UPDATE ON SPJ.SPJ TO 'role_operator' WITH GRANT
OPTION;
```

```
mysql> GRANT ALL PRIVILEGES ON SPJ.* TO 'role_manager' WITH GRANT OPTION;
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT SELECT, INSERT, UPDATE ON SPJ.S TO 'role_operator' WITH GRANT OPTION;
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT SELECT, INSERT, UPDATE ON SPJ.P TO 'role_operator' WITH GRANT OPTION;
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT SELECT, INSERT, UPDATE ON SPJ.J TO 'role_operator' WITH GRANT OPTION;
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT SELECT, INSERT, UPDATE ON SPJ.SPJ TO 'role_operator' WITH GRANT OPTION;
Query OK, 0 rows affected (0.00 sec)
```

3.2 列级授权

授予 role_viewer 部分列的只读权限（不能查看 STATUS、WEIGHT 等敏感列）：

```
GRANT SELECT (SNO, SNAME, CITY) ON SPJ.S TO 'role_viewer';
GRANT SELECT (PNO, PNAME, COLOR) ON SPJ.P TO 'role_viewer';
GRANT SELECT (JNO, JNAME, CITY) ON SPJ.J TO 'role_viewer';
GRANT SELECT (SNO, PNO, JNO, QTY) ON SPJ.SPJ TO 'role_viewer' WITH GRANT
OPTION;
```

```
mysql>
mysql> GRANT SELECT (SNO, SNAME, CITY) ON SPJ.S TO 'role_viewer';
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT SELECT (PNO, PNAME, COLOR) ON SPJ.P TO 'role_viewer';
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT SELECT (JNO, JNAME, CITY) ON SPJ.J TO 'role_viewer';
Query OK, 0 rows affected (0.00 sec)
```

3.3 直接对用户授权

```
-- user1 额外获得 SPJ 表的 INSERT 权限
GRANT SELECT, INSERT ON SPJ.SPJ TO 'user1'@'localhost' WITH GRANT OPTION;
```

```
-- user2 获得对 QTY 列的 UPDATE 权限
GRANT UPDATE (QTY) ON SPJ.SPJ TO 'user2'@'localhost' WITH GRANT OPTION;
```

4. 检验授权结果

切换到 user1 登录测试:

```
-- mysql -u user1 -p
USE SPJ;
SELECT * FROM SPJ;           -- 应成功 (有 SELECT 权限)
INSERT INTO SPJ VALUES ('S1', 'P1', 'J2', 150); -- 应成功 (有 INSERT 权限)
```

切换到 user3 登录测试:

```
-- mysql -u user3 -p
USE SPJ;
SELECT SNO, SNAME, CITY FROM S; -- 应成功 (有部分列 SELECT 权限)
SELECT * FROM S;                -- 应报错: 权限不足 (STATUS 列未授权)
```

```
mysql> USE SPJ;
Database changed
mysql> INSERT INTO SPJ VALUES ('S1', 'P1', 'J2', 150);
Query OK, 1 row affected (0.00 sec)

mysql> SELECT * FROM SPJ WHERE JNO = 'J2';
+----+-----+-----+-----+
| SNO | PNO | JNO | QTY |
+----+-----+-----+-----+
| S1  | P1  | J2  | 150 |
| S1  | P2  | J2  | 100 |
| S2  | P3  | J2  | 200 |
| S2  | P5  | J2  | 100 |
| S5  | P6  | J2  | 200 |
+----+-----+-----+-----+
5 rows in set (0.00 sec)
```

```
mysql> USE SPJ;
Database changed
mysql> SELECT SNO, SNAME, CITY FROM S;
+----+-----+-----+
| SNO | SNAME | CITY |
+----+-----+-----+
| S1  | 精益 | 天津 |
| S2  | 盛锡 | 北京 |
| S3  | 东方红 | 北京 |
| S4  | 丰泰盛 | 天津 |
| S5  | 为民 | 上海 |
+----+-----+-----+
5 rows in set (0.00 sec)

mysql> SELECT * FROM S;
ERROR 1142 (42000): SELECT command denied to user 'user3'@'localhost' for table 's'
```

5. 权限传播（用户给用户授权）

user1 利用 WITH GRANT OPTION 将权限传播给其他用户：

```
-- user1 登录后执行
GRANT SELECT ON SPJ.SPJ TO 'user2'@'localhost';
GRANT INSERT ON SPJ.SPJ TO 'user2'@'localhost';
GRANT SELECT (SNO, PNO, JNO, QTY) ON SPJ.SPJ TO 'user3'@'localhost';
```

检验传播结果：

```
-- 切换到 user2
SELECT * FROM SPJ.SPJ; -- 应成功

-- 切换到 user3
SELECT SNO, PNO, JNO, QTY FROM SPJ.SPJ; -- 应成功
```

```
mysql> USE SPJ;
Database changed
mysql> GRANT SELECT ON SPJ.SPJ TO 'user2'@'localhost';
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT INSERT ON SPJ.SPJ TO 'user2'@'localhost';
Query OK, 0 rows affected (0.00 sec)

mysql> GRANT SELECT (SNO, PNO, JNO, QTY) ON SPJ.SPJ TO 'user3'@'localhost';
Query OK, 0 rows affected (0.00 sec)
```

6. 使用 REVOKE 收回权限

6.1 收回角色的权限

```
REVOKE INSERT ON SPJ.S FROM 'role_operator';
REVOKE INSERT ON SPJ.P FROM 'role_operator';
REVOKE INSERT ON SPJ.J FROM 'role_operator';
REVOKE INSERT ON SPJ.SPJ FROM 'role_operator';
```

6.2 收回用户的权限

```
REVOKE INSERT ON SPJ.SPJ FROM 'user1'@'localhost';
```

6.3 收回用户的角色

```
REVOKE 'role_manager' FROM 'user1'@'localhost';
SHOW GRANTS FOR 'user1'@'localhost';
```

6.4 级联收回 (CASCADE)

```
REVOKE SELECT ON SPJ.SPJ FROM 'user1'@'localhost' CASCADE;
```

级联收回后，user1 传播给 user2、user3 的 SELECT 权限也将被收回。